

Mapeo de preguntas a requisitos normativos y marcos de referencia

Tabla de correspondencia entre las preguntas de la Encuesta SASE y los principales requisitos normativos y marcos de referencia relevantes (ENS, NIS2, GDPR, Zero Trust, etc.).

Tabla de mapeo detallado

Bloque	Código pregunta	Tema principal	Normas / Marcos asociados	Justificación resumida
Datos generales	G1–G5	Tipo y tamaño de organización, teletrabajo	NIS2 (ámbito subjetivo), ENS (ámbito de aplicación)	Determinan si la organización está dentro del alcance de NIS2 y ENS y permiten segmentar el análisis por criticidad.
Arquitectura	A1	Modelo de acceso remoto (VPN vs ZTNA)	NIS2 (gestión de riesgos, control de acceso), ENS (principio de acceso autorizado, medidas de protección)	La transición de VPN amplia a ZTNA refuerza el control de acceso y la segmentación lógica requeridos por NIS2 y ENS.
Arquitectura	A2	Uso de plataforma SASE/SSE	NIS2 (seguridad de redes y sistemas), ENS (seguridad de interconexiones, servicios en la nube)	Evalúa el grado de adopción de una arquitectura que facilita la aplicación homogénea de medidas técnicas exigidas por las normas.
Arquitectura	A3	Cobertura SASE sobre tráfico cloud	ENS (servicios en la nube), GDPR (protección de datos personales), NIS2 (seguridad de la cadena de suministro)	El ruteo del tráfico cloud a través de SASE permite controlar cifrado, registro, DLP y acceso, alineado con ENS, GDPR y NIS2.
Arquitectura	A4	Cobertura SASE/SD-WAN en sedes	ENS (interconexiones, redes), NIS2 (resiliencia de servicios esenciales)	La integración de sedes en SD-WAN/SASE mejora la resiliencia y la aplicación coherente de políticas de seguridad.

Identidad / ZT	B1	MFA en usuarios sensibles	NIS2 (control de acceso, autenticación fuerte), ENS (medidas de control de acceso)	MFA es un requisito explícito o implícito en controles de acceso robustos y reduce riesgo de credenciales comprometidas.
Identidad / ZT	B2	Políticas contextuales	Zero Trust (NIST, ENISA), NIS2 (gestión de riesgos), ENS (seguridad por defecto)	El acceso basado en contexto refuerza el principio de “nunca confiar, verificar siempre” y ajusta el riesgo dinámicamente.
Identidad / ZT	B3	Segmentación de acceso	NIS2 (seguridad de redes y sistemas), ENS (segmentación y separación)	La segmentación granular es clave para limitar el movimiento lateral y contener incidentes, en línea con ambas normas.
Identidad / ZT	B4	Cobertura ZTNA	Zero Trust (NIST SP 800-207), NIS2, ENS	ZTNA implementa el principio de acceso mínimo a aplicaciones, alineado con la arquitectura Zero Trust recomendada.
Identidad / ZT	B5	Roadmap Zero Trust	NIS2 (gestión de riesgos y planificación), ENISA ZT	Un roadmap formaliza la transición estratégica hacia modelos de confianza cero y facilita la rendición de cuentas.

Rendimiento / QoE	C1	Medición de latencia a SaaS	ENS (calidad de servicios, continuidad), NIS2 (continuidad de servicios esenciales)	Medir latencia y rendimiento es crucial para garantizar que las medidas de seguridad no degraden servicios críticos.
Rendimiento / QoE	C2	SLOs de experiencia	ENS (gestión de la calidad), NIS2 (continuidad y mitigación de impacto)	SLOs permiten gestionar la experiencia y la disponibilidad como parte de la resiliencia operativa exigida.
Rendimiento / QoE	C3	Percepción de impacto de SASE	ENS (servicio al ciudadano), marcos de experiencia digital	Evalúa el equilibrio entre seguridad y usabilidad, clave para la adopción sostenida y los objetivos de servicio público.
Rendimiento / QoE	C4	Visibilidad por tipo de tráfico	ENS (monitorización), NIS2 (detección de incidentes)	Diferenciar QoE por tipo de tráfico ayuda a priorizar recursos para servicios esenciales (voz de emergencia, sistemas clínicos, etc.).
Seguridad / SOC	D1	Integración telemetría SASE-SIEM	NIS2 (detección y respuesta a incidentes), ENS (registro y monitorización)	La integración es esencial para correlación de eventos, detección avanzada y respuesta coordinada.
Seguridad / SOC	D2	Métricas MTTD/MTTR SASE	NIS2 (gestión de incidentes), ENS (respuesta a incidente)	Permiten demostrar eficacia en la detección y respuesta, exigidas por ambos marcos.

Seguridad / SOC	D3	Métricas de amenazas bloqueadas	NIS2, ENS (protección frente a malware, phishing, etc.)	Evidencian la efectividad de los controles perimetrales cloud centrados en SASE.
Seguridad / SOC	D4	Gestión de falsos positivos	NIS2 (gestión de riesgos), ENS (proporcionalidad de controles)	Equilibra la seguridad con la operativa, evitando fatiga de alertas y pérdida de eficacia real.
Seguridad / SOC	D5	Evaluación de impacto de controles avanzados	ENS (eficacia de medidas), NIS2 (proporcionalidad y gestión de riesgos)	Ayuda a decidir entre endurecimiento de políticas y mantenimiento de niveles aceptables de servicio.
Cumplimiento	E1	Uso de SASE para medidas ENS cloud	ENS (servicios cloud), NIS2 (seguridad de la cadena de suministro)	Mide hasta qué punto SASE actúa como plano de control para aplicar sistemáticamente medidas ENS en cloud.
Cumplimiento	E2	Alineamiento SASE-ENS/NIS2	ENS, NIS2, GDPR	Evalúa la existencia de un mapeo formal de controles SASE a obligaciones normativas, facilitando auditorías.
Cumplimiento	E3	Gestión de terceros	NIS2 (gestión de proveedores), ENS (servicios prestados por terceros)	Refleja la madurez en la selección, contratación y supervisión de proveedores SASE/SSE/SD-WAN.

Cumplimiento	E4	Auditorías y pruebas de eficacia	NIS2, ENS, ISO 27001 (A.12, A.18)	Indica la integración de SASE en el ciclo de mejora continua y evaluación independiente.
Madurez / Gov.	F1	Nivel de madurez SASE	NIS2 (gestión de riesgos), marcos de madurez ZT	Clasifica el estado de adopción desde piloto hasta optimización, útil para planes de mejora.
Madurez / Gov.	F2	Consolidación de herramientas	NIS2 (eficiencia de medidas), ENS (gestión de activos)	La consolidación reduce superficie de ataque, complejidad y errores de configuración.
Madurez / Gov.	F3	Gobernanza redes-seguridad-riesgos	NIS2 (gobernanza de ciberseguridad), ENS (organización de la seguridad)	Evalúa la existencia de órganos de decisión integrados y responsables claros.
Madurez / Gov.	F4	Percepción directiva de SASE	NIS2 (responsabilidad del órgano de dirección)	Mide el grado en que la dirección entiende y apoya SASE como elemento estratégico.
Continuidad	G1	SASE en planes de continuidad	NIS2 (gestión de continuidad), ENS (plan de continuidad de la actividad)	Indica si SASE se contempla explícitamente en planes de contingencia y recuperación.
Continuidad	G2	Redundancia y HA	ENS (disponibilidad, redundancia), NIS2 (resiliencia)	Mide el nivel de redundancia y preparación ante fallos de red/PoPs/proveedores.
Continuidad	G3	Modelización del riesgo SASE	NIS2 (gestión de riesgos), marcos de análisis de riesgo (ISO 27005)	Evalúa si el riesgo asociado a SASE está cuantificado y modelizado.

Negocio / ROI	H1	Existencia de IGM	NIS2 (enfoque basado en riesgo), ENS (gestión de la seguridad)	Un índice de madurez formal ayuda a priorizar inversiones y justificar decisiones.
Negocio / ROI	H2	Uso de ROI y métricas financieras	NIS2 (eficiencia de medidas), marcos de ROI de ciberseguridad	Refleja la capacidad de vincular SASE con valor económico y coste evitado.
Negocio / ROI	H3	Beneficios percibidos	NIS2 (beneficio en reducción de riesgo), ENS	Permite relacionar la inversión en SASE con objetivos de seguridad, cumplimiento y negocio.
Negocio / ROI	H4	Obstáculos principales	NIS2 (gestión de riesgos y recursos), ENS (organización)	Identifica barreras culturales, técnicas y presupuestarias que condicionan el cumplimiento.
Abiertas	O1–O5	Narrativa cualitativa	Todos los anteriores	Proporcionan contexto cualitativo que puede enlazarse con múltiples requisitos y marcos.